

Estudio de Caso Forense: El Ataque Silencioso a la Nube

Análisis Técnico del Incidente de Cryptojacking a Clústeres de Servidores Empresariales

Módulo: MTCS-20

Segundo Corte (35%)

RA 2.1: Entornos Seguros y Auditoría

Semana 06 • Sesión 01

Grupo: 501

Caso Real: Tesla / AWS Kubernetes

TIPO DE AMENAZA

Cryptojacking (Minería no autorizada de criptomonedas).

CRIPTOMONEDA EXPLOTADA

Monero (XMR), optimizada para silencio de servidor.

INFRAESTRUCTURA AFECTADA

Clústeres Kubernetes en la nube bajo Debian/Linux.

VECTOR DE ACCESO

Consola de nube sin autenticación de contraseña.

CASO DOCUMENTADO

Incidente Tesla Motors / AWS (RedLock, 2018).

MÉTODO DE DETECCIÓN

Auditoría de telemetría y facturación anómala de CPU.

1. Crónica del Incidente: La Invasión Invisible

A principios de 2018, analistas de ciberseguridad descubrieron una anomalía desconcertante en uno de los entornos en la nube más avanzados del mundo: la infraestructura corporativa de Tesla alojada en Amazon Web Services (AWS). Los atacantes no penetraron la red para robar planos de vehículos autónomos, ni para filtrar datos personales de clientes, ni para desplegar un *Ransomware* que paralizara las plantas de ensamblaje. El ataque fue completamente silencioso e imperceptible a simple vista:

1) Los atacantes ubicaron una consola de administración de contenedores (Kubernetes) configurada por omisión sin contraseña hacia internet. 2) Una vez dentro, no alteraron bases de datos ni códigos fuente para no encender alarmas de integridad. 3) Desplegaron scripts dentro de instancias virtuales con sistema operativo **Linux**, programados para forzar los procesadores al 100% de capacidad minando criptomonedas las 24 horas del día. 4) Ocultaron la dirección IP del servidor de cobro detrás de la red de Cloudflare para esquivar las listas negras de cortafuegos.

El compromiso no fue detectado por quejas de usuarios ni por caídas de servicio, sino por la **telemetría financiera**: las facturas de consumo energético y cómputo de la nube comenzaron a triplicarse inexplicablemente.

2. ¿Por qué los atacantes eligen la Nube y Servidores Linux?

Para un atacante moderno, una computadora de escritorio doméstica es un objetivo deficiente para la minería: genera escasos centavos al mes tras un desgaste acelerado. En contraste, la infraestructura en la nube ofrece ventajas masivas:

Procesadores Industriales (Intel Xeon y AMD EPYC): Los centros de datos de proveedores como Google Cloud y AWS cuentan con procesadores de servidor de alta densidad, con decenas de núcleos y gigabytes de memoria RAM de alta velocidad. Secuestrar diez servidores en la nube equivale al poder de cómputo de cientos de oficinas convencionales, financiado al 100% por la empresa víctima.

Servidores en Modo Headless: Más del 90% de los servidores en la nube operan bajo distribuciones Linux (Debian, Ubuntu Server) en modo *Headless* (sin interfaz gráfica, sin ventanas ni ratón). Toda la operación se realiza mediante consola Bash. Por ende, ningún usuario ve una pantalla trabada; la invasión solo se detecta interrogando el sistema mediante comandos forenses.

3. Batería de Auditoría Pericial en Terminal Linux

Cuando un equipo de respuesta a incidentes (Blue Team) audita una máquina virtual sospechosa en la nube, ejecuta una secuencia estricta de verificación en consola:

Fase 1: Identidad y Carga del Sistema (whoami, id, uptime):

```
usuario@cloudshell:~$ whoami && id
uid=1000(usuario) gid=1000(usuario) groups=1000(usuario),27(sudo)
usuario@cloudshell:~$ uptime
15:12:44 up 14:18, 1 user, load average: 4.88, 4.75, 4.60
```

Interpretación: El usuario UID 1000 confirma que el atacante operó en espacio de usuario sin corromper el núcleo root (UID 0). El *load average* en 4.88 para 4 núcleos evidencia que la máquina está saturada al 100% ejecutando tareas continuas en segundo plano.

Fase 2: Silicio y Memoria RAM (lscpu, free -h):

```
usuario@cloudshell:~$ lscpu | grep -E "Model name|CPU(s):"
CPU(s): 4 | Model name: Intel(R) Xeon(R) CPU @ 2.80GHz
usuario@cloudshell:~$ free -h
Mem: 15Gi total, 14Gi used, 420Mi free, 850Mi available
```

Interpretación: Revela la presencia de procesadores Intel Xeon empresariales con 15 GB de RAM consumidos casi en su totalidad por procesos huérfanos.

Fase 3: Inspección del Directorio /etc (/etc/os-release, /etc/passwd):

```
usuario@cloudshell:~$ cat /etc/passwd | tail -n 3
tcpdump:x:107:112::/nonexistent:/usr/sbin/nologin
usuario:x:1000:1000:Google Cloud Shell User:/home/usuario:/bin/bash
```

Interpretación: Las cuentas de servicio terminan en /usr/sbin/nologin, garantizando que el intruso no creó usuarios persistentes con shell interactiva; el malware opera en memoria temporal.

Fase 4: Red y Paradoja de Doble IP (hostname -I vs curl ifconfig.me):

```
usuario@cloudshell:~$ hostname -I && curl -s ifconfig.me
10.88.0.4 (IP privada en contenedor) | 34.125.74.198 (IP pública en internet)
```

Interpretación: La máquina vive en una subred privada clase A (10.88.0.4), pero a través de la pasarela NAT sale a internet con la IP pública 34.125.74.198. Al rastrearla en iplocation.io, se ubica el centro de datos en Iowa, Estados Unidos, identificando la ruta de fuga hacia los servidores de minería.

4. Comparativa Táctica: Ransomware vs. Cryptojacking

CRITERIO TÉCNICO	RANSOMWARE (SECUESTRO DE DATOS)	CRYPTOJACKING (SECUESTRO DE SILICIO)
Modo de Operación	Altamente ruidoso: pantallas de bloqueo y notas de extorsión.	Completamente silencioso e invisible a simple vista.
Impacto en Archivos	Cifra o borra bases de datos y carpetas institucionales.	No toca ni altera los archivos; solo parasita recursos.
Objetivo Financiero	Exigir un pago único a cambio de la clave de rescate.	Generar flujo constante de criptomonedas (Monero).

CRITERIO TÉCNICO	RANSOMWARE (SECUESTRO DE DATOS)	CRYPTOJACKING (SECUESTRO DE SILICIO)
Síntoma Principal	Archivos inaccesibles con extensiones extrañas.	CPU al 100%, saturación térmica y facturación disparada.
Herramienta de Detección	Alertas visuales de antivirus y reporte de usuarios.	Auditoría de consola en Linux (uptime, lscpu, nano).



ORGANIZADOR VISUAL: ANATOMÍA DEL INCIDENTE EN LA NUBE

Instrucción: Reproduce en tu libreta el siguiente esquema de 3 columnas como evidencia formativa de la Sesión 01.

1. VECTOR DE ATAQUE

- **Amenaza:** Cryptojacking en la nube.
- **Brecha:** Consola expuesta sin contraseña.
- **Objetivo:** Robo de ciclos de cómputo.
- **Evasión:** Sin cifrar datos ni dejar notas.

2. SÍNTOMAS TÉCNICOS

- **CPU:** 100% de uso sostenido.
- **Carga:** Load average crítico (> 4.0).
- **Factura:** Cobro cloud triplicado.
- **Entorno:** Servidor remoto Headless (Linux).

3. RESPUESTA FORENSE (LINUX)

- **Identidad:** whoami e id (UID 1000).
- **Hardware:** lscpu (Intel Xeon) y free -h.
- **Directorio:** cat /etc/passwd (nologin).
- **Red:** hostname -I vs curl ifconfig.me.
- **Dictamen:** Registro en nano bitacora.txt.



CUESTIONARIO DE ANÁLISIS FORENSE (RESPONDER A MANO EN LIBRETA)

1. ¿Por qué el ataque a Tesla en 2018 no fue detectado por los usuarios del sistema ni alteró las bases de datos?
2. ¿Qué ventaja económica encuentra un atacante al minar en procesadores **Intel Xeon** en la nube en lugar de PCs domésticas?
3. ¿Por qué en ciberseguridad defensiva los servidores de producción operan en **modo Headless** (sin interfaz gráfica)?
4. ¿Cuál es la diferencia entre la dirección IP privada entregada por hostname -I y la obtenida mediante curl ifconfig.me?
5. ¿Cuáles son los atajos de teclado indispensables en el editor nano para guardar los cambios y salir a la terminal?

Evidencia formativa Sesión 01: Estudio de caso analizado, organizador visual en libreta y cuestionario respondido.

CONALEP Plantel Pachuca de Soto • MTCS-20 • Segundo Corte • RA 2.1

SELLO DEL DOCENTE